

Integrated Hospital Management System

Local Deployment, Security Hardening & Source Code Protection —
Implementation Guide

CLIENT ORGANISATION

Franciscan Solidarity of Hearts Hospital

SITE / ANNEX

FRANSoHH (Shisong Annex) SOA

ABBREVIATION

TSSF SOA

SOFTWARE PLATFORM

ZAIZENS HMS · hms-node-v3

DEPLOYMENT MODEL

On-premises Windows · Hospital LAN

Document version

2.4 — Premium edition

Publication date

May 2026

Prepared for

TSSF SOA IT & Hospital Administration

Prepared by

ZAIZENS Implementation Team

Table of contents

01	Executive summary	12	Start, verify, and handover testing
02	Client site profile — TSSF SOA	13	Post-deployment hospital configuration
03	Scope, objectives, and deliverables	14	Solution licensing (vendor control)
04	System requirements	15	Protecting source code from modification
05	Architecture and network design	16	Preventing unauthorized access
06	Implementation phases	17	Application-level security controls
07	Pre-deployment checklist	18	Backup strategy and implementation
08	Step-by-step local deployment	19	Run HMS as a Windows service
09	Database setup for TSSF SOA	20	Troubleshooting
10	Environment & branding configuration	22	Complementary implementation scripts
11	Build and deploy application artifacts	23	Appendix

1. Executive summary

This document is the authoritative implementation guide for deploying **ZAIZENS Integrated HMS** at **Franciscan Solidarity of Hearts Hospital — FRANSoHH (Shisong Annex) SOA**, abbreviated **TSSF SOA**. The system runs on a dedicated Windows server inside the hospital network and serves clinical, operational, HR, and financial workflows through role-based portals.

The guide covers full installation (Node.js, MySQL, application build, Windows service), TSSF-specific branding, operational validation, and a **defence-in-depth security model** that addresses two distinct risks:

- **Unauthorized modification** of application source, configuration, or licensing logic on the server.
- **Unauthorized access** to the server, database, admin functions, or patient data by staff or outsiders.

Important distinction: HMS is a Node.js application. Unlike compiled desktop software, some runtime files (EJS views, server JavaScript) must remain on disk in a form Node can execute. Protection therefore combines *minimal deployment artifacts, operating-system hardening, access control, and optional obfuscation* — not a single “hide all code” switch.

2. Client site profile — TSSF SOA

Attribute	Value
Hospital name	Franciscan Solidarity of Hearts Hospital
Annex / site label	FRANSoHH (Shisong Annex)
Organisation abbreviation	TSSF SOA
Product branding in UI	ZAIZENS (platform) + TSSF SOA (facility)
Receipt / thermal slip header	FRANSoHH (Shisong Annex)
Financial / letterhead org name	TSSF SOA
Currency context	FCFA (Central African CFA franc) — configured in financial modules
Languages	English and French (full i18n via <code>locales/en</code> and <code>locales/fr</code>)

Branding is driven by environment variables read by `lib/hmsBrand.js` and applied across login pages, navigation, print letterheads, payment slips, and management reports. Section 10 provides the exact `.env` block for TSSF SOA.

3. Scope, objectives, and deliverables

3.1 In scope

- Installation of HMS application stack on a local Windows server at TSSF SOA
- MySQL database provisioning and data migration (if applicable)
- Production UI bundle deployment (`public/dist/`)
- TSSF SOA branding and facility configuration
- Role-based access control setup via `/hms-admin/access`
- Super Admin deployment profile / module configuration

- Server hardening: NTFS permissions, service account, firewall, HTTPS front-end
- Source protection package (exclude dev sources; optional obfuscation)
- Backup schedule for database, uploads, and configuration
- User acceptance testing (UAT) and go-live checklist

3.2 Out of scope (unless separately contracted)

- Vendor license generator deployment at TSSF SOA (private signing keys stay with ZAIZENS)
- Hardware procurement (server, UPS, network switches)
- Internet connectivity / WAN design beyond hospital LAN recommendations
- Staff training curriculum (refer to hospital training plan)

3.3 Success criteria

- ☐ Staff can log in from hospital workstations and reach assigned portals
 - ☐ OPD queue, patient registration, and at least one clinical workflow operate end-to-end
 - ☐ Database backups run automatically and restore successfully in a test
- ☐ Application folder is not writable by standard user accounts
 - ☐ Only authorised IT accounts can RDP to the HMS server
 - ☐ HTTPS enabled for browser access (valid internal or public certificate)
 - ☐ Diagnostic report (`diagnostic2-output.txt`) shows all critical checks OK

4. System requirements

Component	Minimum	Recommended for TSSF SOA production
Server OS	Windows Server 2019	Windows Server 2022 Standard
CPU	4 cores	8 cores (Xeon or equivalent)
RAM	8 GB	16 GB (MySQL + Node + OS headroom)
System disk	128 GB SSD	256 GB SSD (OS + application)
Data disk	—	Separate volume for MySQL data and <code>uploads/</code>
Node.js	18 LTS	20 LTS or 22 LTS (64-bit)
MySQL	8.0.x	8.0.x — InnoDB, utf8mb4_unicode_ci
Network	Gigabit LAN	Dedicated VLAN for servers; no direct internet on DB port
UPS	Recommended	Required for production (graceful shutdown)
Browser clients	Chrome / Edge current	Managed hospital workstations, locked-down extensions

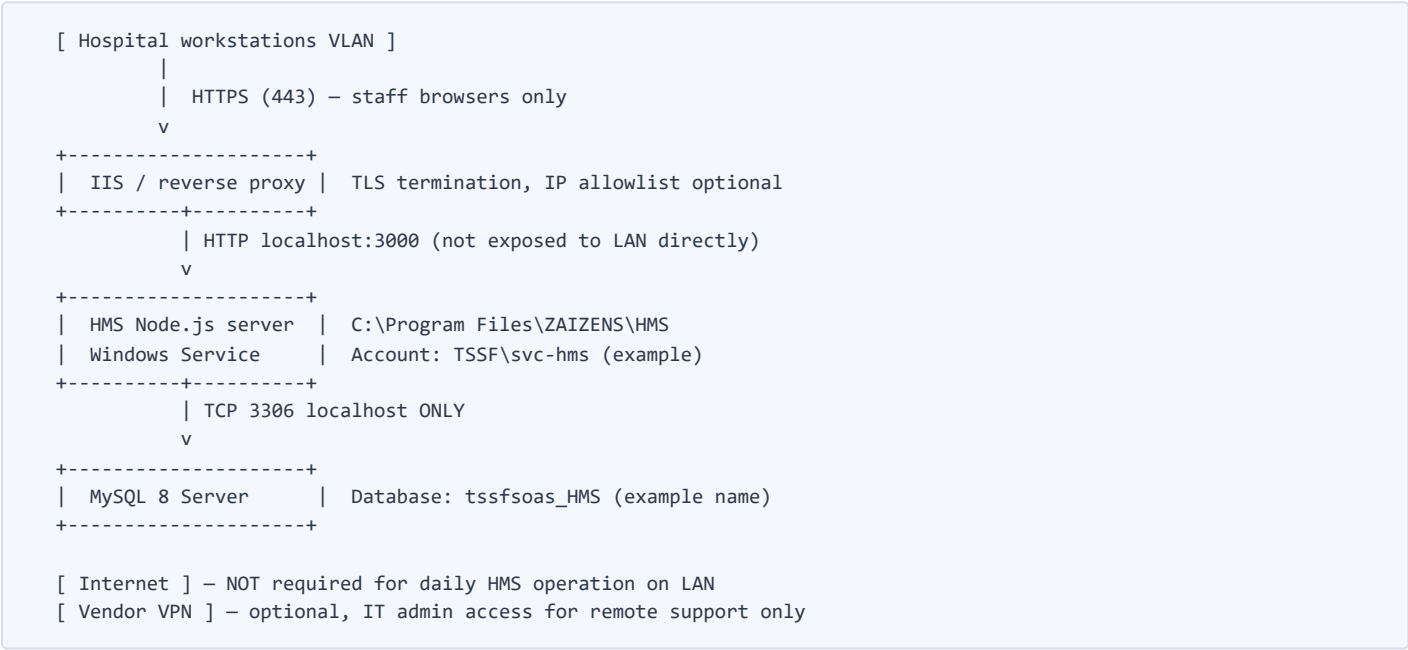
5. Architecture and network design

5.1 Logical components

Layer	Technology	Notes
HTTP / API	Express (<code>app.js</code>)	Single Node process (or PM2 cluster if scaled later)

Layer	Technology	Notes
Staff UI	React bundles in <code>public/dist/</code>	Pre-built; no Node required on client PCs
Legacy pages	EJS templates in <code>views/</code>	Server-rendered HTML
Database	MySQL 8	All PHI and transactional data
Sessions	MySQL session store	Persist across Node restarts
File uploads	<code>uploads/</code> folder	Documents, images — must be backed up
i18n	<code>locales/en</code> , <code>locales/fr</code>	English + French UI
Access control	<code>tbl_acl_*</code> tables	Managed at <code>/hms-admin/access</code>

5.2 Recommended network layout (TSSF SOA LAN)



5.3 Ports and firewall rules

Port	Service	Exposure	Rule
443	HTTPS (IIS → HMS)	Hospital LAN VLAN	Allow from workstation subnet only
3000	Node (direct)	Loopback only in production	Block inbound on LAN interface
3306	MySQL	Loopback only	Deny all remote connections
3389	RDP	IT admin subnet / VPN only	Deny from general staff VLAN
5055	License generator	Not on TSSF server	Vendor machine only — never at hospital

6. Implementation phases

Phase	Activities	Duration (indicative)
P0 — Prepare	Server procured, OS patched, accounts planned, backup target defined	1–3 days
P1 — Install stack	Node, MySQL, firewall, service account, folders	1 day
P2 — Deploy HMS	Protected package, <code>.env</code> , DB import/create, UI bundles	1 day
P3 — Secure	NTFS ACLs, Windows service, IIS/HTTPS, deny write on code	1 day
P4 — Configure	Super Admin profiles, ACL roles, TSSF branding, modules	2–5 days
P5 — UAT	Clinical + admin test scenarios, French UI spot-check, backup restore test	3–7 days
P6 — Go-live	Freeze change window, production cutover, hypercare support	1 day + 2 weeks support

7. Pre-deployment checklist

- ☐ Windows Server joined to hospital domain (recommended) or standalone with local admin policy
- ☐ Server hostname documented (e.g. `TSSF-HMS-01`)
- ☐ Static IP assigned on server VLAN
- ☐ Node.js 18+ installed (64-bit), verified with `node -v`
- ☐ MySQL 8 installed as Windows service, root password vaulted
- ☐ Service account `svc-hms` created — no interactive logon, password vaulted
- ☐ Antivirus exclusion configured for `uploads/` scan-on-write (not blind exclude of entire app)
- ☐ Backup destination ready (NAS or secondary disk) — encrypted
- ☐ Deployment package built with `npm run build:deploy:protected`
- ☐ TSSF `.env` prepared offline — not emailed in plain text
- ☐ SSL certificate obtained for internal DNS name (e.g. `hms.tssf-soa.local`)
- ☐ Implementation team has Super Admin credentials for first login
- ☐ Change control register opened for go-live window

8. Step-by-step local deployment

Perform these steps on the **TSSF SOA HMS server** using an Administrator account. After Section 15 hardening, day-to-day operation should not require Administrator login.

1 Install prerequisites

```
winget install OpenJS.NodeJS.LTS
winget install Oracle.MySQL
```

Verify: `node -v` (≥ 18) and `mysql --version`.

2 Create installation paths

```
mkdir "C:\Program Files\ZAIZENS\HMS"  
mkdir "D:\HMS-Data\uploads"  
mkdir "D:\HMS-Data\mysql-backups"  
mkdir "D:\HMS-Data\hms-backups"
```

Using drive `D:` for data separates OS from patient uploads and backups.

3 Deploy protected application package

On the build machine (vendor / implementation laptop — not staff workstations):

```
cd C:\HMS_JS  
npm run build:ui  
npm run build:deploy:protected
```

Copy the entire contents of `dist\hms-deploy\` to `C:\Program Files\ZAIZENS\HMS\`. Do **not** copy the full Git repository, `frontend\src`, or `license-generator\`.

4 Link or move writable data folders

```
mklink /D "C:\Program Files\ZAIZENS\HMS\uploads" "D:\HMS-Data\uploads"  
mkdir "C:\Program Files\ZAIZENS\HMS\tmp"
```

5 Install production Node dependencies (if not already in package):

```
cd "C:\Program Files\ZAIZENS\HMS"  
npm ci --omit=dev
```

6 Place TSSF `.env` — see Section 10. Restrict ACL immediately after creation.

7 Configure MySQL — see Section 9.

8 Register Windows service — see Section 19.

9 Configure IIS reverse proxy + HTTPS — see Section 16.3.

10 Apply NTFS hardening — see Section 15.

11 Run validation — see Section 12.

9. Database setup for TSSF SOA

9.1 Database credentials in implementation scripts

All files under `C:\HMS_JS\docs\scripts\` use the **hardened 15-character password** below. Run script `01b-rotate-to-hardened-password.sql` first if MySQL still has the legacy password `Hellt0cell` .

Setting	Value (scripts & deployment)
Database name	<code>tssfsoas_HMS</code>
Application user	<code>tssfsoas_Admin</code>
Hardened password (15 chars)	<code>Ts\$fSOA2026!Hms</code>
Host	<code>localhost</code> (port <code>3306</code>)
Connection URL	<code>mysql://tssfsoas_Admin:Ts\$fSOA2026!Hms@localhost:3306/tssfsoas_HMS</code>

9.2 Password policy

Policy item	Requirement
Minimum length	15 characters
Character classes	Uppercase, lowercase, digit, symbol
Legacy password (pre-rotation)	<code>Hellt0cell</code> — replace via script <code>01b</code>

9.3 Create database and user (SQL — from script 01)

```
mysql -u root -p < "C:\HMS_JS\docs\scripts\01-create-mysql-database.sql"
```

Or run manually:

```
CREATE DATABASE tssfsoas_HMS CHARACTER SET utf8mb4 COLLATE utf8mb4_unicode_ci;

CREATE USER 'tssfsoas_Admin'@'localhost' IDENTIFIED BY 'Ts$fSOA2026!Hms';

GRANT SELECT, INSERT, UPDATE, DELETE, CREATE, ALTER, INDEX, DROP,
      CREATE TEMPORARY TABLES, LOCK TABLES, EXECUTE, CREATE VIEW,
      SHOW VIEW, CREATE ROUTINE, ALTER ROUTINE, TRIGGER, EVENT
  ON tssfsoas_HMS.* TO 'tssfsoas_Admin'@'localhost';

FLUSH PRIVILEGES;
```

Do **not** grant `SUPER` , `FILE` , or `SHUTDOWN` . Do **not** create `'tssfsoas_Admin'@'%'` — localhost only.

9.4 Import existing TSSF data

If migrating from a prior HMS instance or staging export:


```
mysql -u tssfsoas_Admin -pTs$fSOA2026!Hms tssfsoas_HMS < hms_export.sql
```

On first boot against an empty database, HMS auto-runs schema helpers (`lib/ensure*Schema.js`) to create required tables. You must still seed at least one admin user in `tbl_employee` .

9.5 MySQL hardening (summary)

- Bind MySQL to `127.0.0.1` in `my.ini` — not `0.0.0.0`
- Disable remote root login; store root password in IT vault only
- Enable binary logging if point-in-time recovery is required
- Schedule nightly logical backups to `D:\HMS-Data\mysql-backups`

9.6 Staff roles reference

Role ID	Typical TSSF SOA use
99	Super Admin — deployment profiles, module slices (implementation team only)
1	Hospital Admin / Medical Director — full admin dashboard
100	Director — management reports, subscription management
2	Physician — clinical portals, OPD, consultations
3+	Nursing, front desk, lab, pharmacy, HR, finance — via Access Control portals

10. Environment & branding configuration

Deploy the production `.env` from the implementation scripts folder:

```
powershell -ExecutionPolicy Bypass -File "C:\HMS_JS\docs\scripts\05-install-env.ps1"
```

Source file: `C:\HMS_JS\docs\scripts\02-tssf-soa.env` — hardened password `Ts$fSOA2026!Hms` (15 characters):

```
PORT=3000
NODE_ENV=production

DB_HOST=localhost
DB_PORT=3306
DB_USER=tssfsoas_Admin
DB_PASSWORD=Ts$fSOA2026!Hms
DB_NAME=tssfsoas_HMS
DATABASE_URL="mysql://tssfsoas_Admin:Ts$fSOA2026!Hms@localhost:3306/tssfsoas_HMS"

SESSION_SECRET=hms-prod-please-replace-with-a-long-random-string
HMS_SESSION_IDLE_MINUTES=15

HMS_BRAND_NAME=ZAIZENS
HMS_PRODUCT_NAME=ZAIZENS Integrated HMS
HMS_LOGIN_SUBTITLE=An integrated HMS
HMS_BRAND_TAGLINE=Digital Intelligence. Redefined.
HMS_FACILITY_LEGAL_NAME=TSSF SOA
HMS_FACILITY_NAME=TSSF SOA
HMS_ORG_NAME=TSSF SOA
HMS_SLIP_HEADER=FRANSoHH (Shisong Annex)
HMS_BRAND_WEBSITE=https://www.zaizens.com/
HMS_LOGO_PATH=img/zaizens-brand.svg
```

```
HMS_FAVICON_PATH=/img/zaizens-favicon.svg
HMS_LETTERHEAD_PATH=/img/hms-letterhead.png?v=20260515
```

Licensing — PUBLIC keys only (from ZAIZENS vendor) # LICENSE_RSA_PUBLIC_KEY_PEM="-----BEGIN PUBLIC KEY-----\n...\n-----END PUBLIC KEY-----" # LICENSE_ED25519_PUBLIC_KEY_PEM="-----BEGIN PUBLIC KEY-----\n...\n-----END PUBLIC KEY-----" # LICENSE_VENDOR_EMAIL=licensing@zaizens.com # HMS_LICENSE_DEPLOYMENT=1 # Optional outbound email for subscription requests # HMS_SMTP_HOST=smtp.example.com # HMS_SMTP_PORT=587 # HMS_SMTP_USER= # HMS_SMTP_PASS= # HMS_SMTP_FROM="TSSF SOA HMS <noreply@tssf-soa.org>"

After saving, restrict the file: only `Administrators`, `SYSTEM`, and `svc-hms` may read it. No `Users` or `Authenticated Users` group access.

11. Build and deploy application artifacts

11.1 What gets built

Artifact	Path	Contains source?
Main UI bundle	<code>public/dist/hms-ui.js</code>	Minified React — no <code>frontend/src</code> on server
Login bundle	<code>public/dist/hms-login.js</code>	Minified
Print bundle	<code>public/dist/hms-print.js</code>	Minified
Server code	<code>app.js</code> , <code>lib/</code> , <code>routes/</code>	Plain or obfuscated JS (see Section 15)
Templates	<code>views/</code>	EJS — required at runtime

11.2 Build commands (implementation machine)

```
npm run build:ui           # compile React → public/dist/
npm run build:deploy       # standard protected package
npm run build:deploy:protected # package + obfuscate lib/ and routes/
```

12. Start, verify, and handover testing

12.1 Start HMS

```
cd "C:\Program Files\ZAIZENS\HMS"
npm start
```

Production: use Windows service (Section 19) — not an interactive `node` window.

12.2 Health and diagnostic checks

Check	URL / command	Pass criteria
Login page	<code>https://hms.tssf-soa.local/login</code>	TSSF branding, no JS errors
Health JSON	<code>/__health</code>	DB connected, boot OK
Boot trace	<code>/__boot</code>	No failed route mounts

Check	URL / command	Pass criteria
Full diagnostic	<code>node diagnostic2.js</code>	Output saved; no FAIL lines on critical items
French UI	Language switcher / <code>/set-lang?lang=fr</code>	Key pages render in French
Slip header	Print test receipt	Shows FRANSoHH (Shisong Annex)

12.3 UAT scenarios (minimum)

- ☐ Register patient → OPD visit → vitals → doctor consultation
- ☐ Front desk queue board / call queue display
- ☐ Lab order and result entry (if module licensed)
- ☐ Pharmacy dispense workflow (if licensed)
- ☐ Staff login with role-appropriate portal redirect
- ☐ Failed login logout / session idle timeout (15 min default)
- ☐ Backup restore drill on non-production copy

13. Post-deployment hospital configuration

- 1 Super Admin** (role 99): open `/super-admin` — select deployment profile (HMS, Full Suite, or custom slices for TSSF SOA).
- 2 Module overrides:** `/super-admin/deployment/:id/modules` — enable/disable nav items per annex policy.
- 3 Access Control:** `/hms-admin/access` — map TSSF roles to portals (front desk, nursing, doctors, lab, pharmacy, HR, finance).
- 4 Solution subscriptions:** `/hms-admin/subscriptions` — activate licensed modules with vendor serials.
- 5 Consultation rooms:** configure rooms and doctor assignments for OPD call queue.
- 6 Service catalog & tariffs:** align with TSSF SOA billing policy (FCFA).
- 7 Staff accounts:** create users; disable default/test accounts; enforce individual credentials.
- 8 Remove Super Admin from daily use:** after go-live, restrict role 99 to implementation/vendor accounts only.

14. Solution licensing (vendor control)

ZAIZENS modules can be gated by cryptographically signed serial numbers. This gives the vendor contractual control over which solutions TSSF SOA may run, independent of file-level protection.

14.1 At TSSF SOA (hospital server)

- Store only **public** keys in `.env` (`LICENSE_RSA_PUBLIC_KEY_PEM` , `LICENSE_ED25519_PUBLIC_KEY_PEM`)
- Directors activate serials at `/hms-admin/subscriptions`
- Never install `license-generator/` or private keys at the hospital

14.2 At ZAIZENS (vendor — off-site)

```
cd license-generator
npm install
npm start
# http://localhost:5055 - paste hospital request codes, issue ZAI1-LIC serials
```

15. Protecting source code from modification

Attackers or curious staff with write access to the HMS folder could alter `app.js`, disable licensing checks, expose hidden routes, or inject backdoors. The following controls are **mandatory for TSSF SOA production**.

15.1 Principle: immutable application, mutable data only

Path	Permissions (svc-hms)	Permissions (Administrators)	Permissions (Users / staff)
C:\Program Files\ZAIZENS\HMS\ (code)	Read & execute	Read & execute (not Full Control in steady state)	No access
uploads\	Modify	Read	No access
tmp\	Modify	Read	No access
.env	Read	Read (change via change control only)	No access
node_modules\	Read & execute	Read & execute	No access

15.2 Apply NTFS ACLs (PowerShell — run as Administrator)

```
$root = "C:\Program Files\ZAIZENS\HMS"
$svc = "TSSF\svc-hms" # adjust domain\account

# Reset and inherit off for root
icacls $root /inheritance:r
icacls $root /grant:r "Administrators:(OI)(CI)(RX)"
icacls $root /grant:r "SYSTEM:(OI)(CI)(F)"
icacls $root /grant:r "${svc}:(OI)(CI)(RX)"
icacls $root /deny "Users:(OI)(CI)(F)"

# Writable folders only
icacls "$root\uploads" /grant:r "${svc}:(OI)(CI)(M)"
icacls "$root\tmp" /grant:r "${svc}:(OI)(CI)(M)"

# Lock .env
icacls "$root\.env" /inheritance:r
icacls "$root\.env" /grant:r "Administrators:(R)"
icacls "$root\.env" /grant:r "SYSTEM:(F)"
icacls "$root\.env" /grant:r "${svc}:(R)"
```

15.3 Deploy minimal artifacts (no development tree)

Never deploy the Git repository to TSSF SOA. The protected package excludes:

- `.git/` — full source history
- `frontend/src/` — readable React source
- `license-generator/` — vendor signing tool

- `scripts/`, `docs/`, `migrations/` — internal tooling
- Development dependencies — use `npm ci --omit=dev`

15.4 Optional: JavaScript obfuscation (included in protected build)

```
npm run build:deploy:protected
```

Obfuscates `lib/` and `routes/` using `javascript-obfuscator`. This deters casual reading and tampering but is not cryptographic security. Combine with NTFS read-only code and change control.

15.5 Optional: bytecode compilation (advanced)

For highest deterrence on server logic, selected modules may be compiled to V8 bytecode (`.jsc`) using `bytenode`. Requires a controlled build pipeline — contact ZAIZENS if TSSF SOA contracts bytecode delivery.

15.6 File integrity monitoring

1. After golden deploy, generate SHA-256 hashes of all files under `lib/`, `routes/`, `app.js`, `views/`:

```
Get-ChildItem -Recurse "C:\Program Files\ZAIZENS\HMS\lib","C:\Program Files\ZAIZENS\HMS\routes","C:\Program Files\ZAIZENS\HMS\app.js" |
  Get-FileHash -Algorithm SHA256 |
  Export-Csv "D:\HMS-Data\hms-backups\integrity-baseline.csv"
```

2. Schedule weekly hash comparison; alert IT if any application file changed outside an approved patch window.
3. Enable Windows audit policy for object access on the HMS folder (optional, high volume).

15.7 Change control policy

Production rule: No manual edits to files under `C:\Program Files\ZAIZENS\HMS` on the live server. All updates must come from a new signed deployment package from ZAIZENS, applied during a documented maintenance window, with pre/post integrity hash verification and rollback plan.

- Maintain a change register: date, version, approver, files changed, test evidence
- Take MySQL backup immediately before any upgrade
- Re-apply NTFS ACLs after upgrade in case installer resets permissions

15.8 What cannot be fully hidden

EJS templates in `views/` remain text files Node must read. Minification of EJS is not standard. Protection relies on **preventing write access** and **preventing read access** by unauthorised OS users — not on hiding template content from a determined administrator with full server access.

16. Preventing unauthorized access

16.1 Physical and facility security

- HMS server in a locked server room or locked rack — not under a reception desk
- USB storage disabled via Group Policy for non-admin accounts (prevents copy-out of `.env` and DB dumps)
- BIOS/boot password; disable boot from USB
- UPS with graceful shutdown script for MySQL and HMS service

16.2 Network access control

- Place HMS on a dedicated server VLAN; no direct routing to guest Wi-Fi
- Windows Firewall: inbound allow 443 from workstation subnet only; deny 3000 and 3306 from LAN
- MySQL bound to `127.0.0.1` only
- Disable unused Windows features (IIS FTP, Telnet, etc.)
- Remote support via VPN only — not port-forwarded RDP from internet

16.3 HTTPS and reverse proxy (IIS example)

Do not expose raw Node on port 3000 to the hospital LAN. Terminate TLS at IIS:

1. Install IIS + URL Rewrite + Application Request Routing (ARR)
2. Create site `hms.tssf-soa.local` with TLS certificate
3. Reverse proxy to `http://127.0.0.1:3000`
4. Optional: require hospital domain authentication at IIS layer (double gate)

16.4 Windows server hardening

Control	Setting
Automatic updates	Enabled — monthly patch window
Local Administrator	Renamed/disabled; use named admin accounts
RDP	NLA required; limited to IT security group
Password policy	14+ chars, lockout after 5 failures
AppLocker / WDAC	Allow only <code>node.exe</code> from Program Files for svc-hms (optional advanced)
Antivirus	Real-time scan; monitor <code>tmp/crash.log</code> for intrusion tools
Audit logging	Enable logon success/failure; forward to SIEM if available

16.5 Service account isolation

The HMS Windows service must run as `svc-hms`, not Local System or an admin user:

- Deny logon locally and deny RDP for `svc-hms`
- Grant "Log on as a service" only
- If service account is compromised, attacker still cannot modify code (read-only ACL)

16.6 Database credential protection

- Unique password for `tssfsoas_Admin` — current: `He1lt0ce11`; hardened standard (15 chars): Section 9.2
- Credentials only in `.env` — never in EJS, JavaScript, or Git
- No phpMyAdmin / MySQL Workbench on server open to LAN
- Encrypt backup files at rest (BitLocker on `D:` or backup tool encryption)

16.7 Secrets and session security

Variable	Purpose	Guidance
<code>SESSION_SECRET</code>	Signs session cookies	64+ random hex; rotate on compromise

Variable	Purpose	Guidance
HMS_SESSION_IDLE_MINUTES	Auto logout idle staff	15 minutes recommended for clinical stations
NODE_ENV=production	Production mode	Do not run with debug flags

16.8 Restrict diagnostic and health endpoints (production hardening)

Endpoints such as `/__health`, `/__boot` expose environment hints. In hardened production, restrict these to localhost or IT subnet via IIS URL Rewrite rules or firewall — not open to all hospital workstations.

17. Application-level security controls

HMS includes built-in controls that protect data and functions even if a user reaches the application URL.

Control	Mechanism	TSSF SOA action
Authentication	Session-based login; bcrypt passwords	Disable plaintext legacy passwords; force password reset
Session idle timeout	HMS_SESSION_IDLE_MINUTES (default 10 min)	Set 15 min; train staff to lock workstations
Role-based access	requireAuth, requirePerm middleware	Configure ACL at <code>/hms-admin/access</code>
Portal isolation	Each role lands on assigned home portal	No shared generic admin accounts
Super Admin gate	Role 99 only on <code>/super-admin</code>	Limit to vendor + IT lead accounts
Module licensing	Signed serials per solution	Activate only contracted modules
Audit trails	Clinical/financial tables, diagnostic corrections	Do not grant DB direct access to staff
Patient portal	Separate session from staff	Public portal on separate URL if exposed

18. Backup strategy and implementation

Patient records, financial transactions, and uploaded documents at **TSSF SOA** depend on reliable backups. This section defines the backup strategy, folder layout, automation scripts, retention rules, and step-by-step restore procedures. Treat backups as a **production requirement** — not an optional IT task.

18.1 Strategy overview — 3-2-1 rule

Rule	TSSF SOA implementation
3 copies of data	Live production + on-server backup disk + offsite copy (NAS tape/USB vault)
2 different media	Local SSD (D:) + network NAS or rotated encrypted USB
1 offsite copy	Daily sync of compressed dumps to offsite NAS or weekly vault USB stored off hospital premises

Metric	Target	Meaning for TSSF SOA
RPO (Recovery Point Objective)	≤ 24 hours	At most one business day of data loss if disaster strikes overnight
RTO (Recovery Time Objective)	≤ 4 hours	HMS restored and clinical workflows usable within half a shift
Backup window	02:00 – 04:00 local	Low OPD activity; after night batch if any

18.2 What to back up

Priority	Asset	Location	Frequency	Retention	Owner
P1 — Critical	MySQL database tssfsoas_HMS	MySQL data directory	Nightly + pre-upgrade	30 daily, 12 monthly	IT / DBA
P1 — Critical	Patient uploads & documents	D:\HMS-Data\uploads	Nightly mirror	7 daily mirrors + 90-day archive	IT
P2 — High	Environment config .env	C:\Program Files\ZAIZENS\HMS\.env	On every change + nightly	All versions in vault	IT lead only
P2 — High	MySQL options file	D:\HMS-Data\hms-backups\mysql-backup.cnf	On change	Vault copy	IT lead only
P3 — Medium	Integrity hash baseline	D:\HMS-Data\hms-backups\	After each deploy	Permanent	IT / vendor
P3 — Medium	Backup logs	D:\HMS-Data\hms-backups\logs\	Continuous	90 days	IT
P4 — Low	Application code	C:\Program Files\ZAIZENS\HMS\	On vendor upgrade only	Last 3 deploy packages	Vendor

Do not rely on copying the live MySQL data folder while MySQL is running — use `mysqldump` or MySQL Enterprise Backup. Logical dumps are portable and consistent when taken with `--single-transaction` on InnoDB tables.

18.3 Backup storage layout

```
D:\HMS-Data\
  uploads\                ← live patient files (backed up nightly)
  mysql-backups\
    tssfsoas_HMS_2026-05-25_020015.sql
    tssfsoas_HMS_2026-05-26_020012.sql
  uploads-backups\
    2026-05-25_020015\      ← robocopy mirror snapshot
    2026-05-26_020012\
  hms-backups\
    config\
      env_2026-05-25_020015.env ← .env snapshot (restricted ACL)
    mysql-backup.cnf        ← MySQL credentials for backup job
    integrity-baseline.csv
    logs\
      backup-2026-05-25_020015.log
```

Enable **BitLocker** on `D:` so backups at rest are encrypted if the disk is stolen.

18.4 Prepare MySQL credentials file (one-time)

Copy the pre-configured file from the scripts folder:

```
copy "C:\HMS_JS\docs\scripts\03-mysql-backup.cnf" "D:\HMS-Data\hms-backups\mysql-backup.cnf"
```

Contents (user `tssfsoas_Admin`, current password `Hellt0cell`). Hardened 15-char reference: `Ts$f50A2026!Hms` — see Section 9.2 (documentation only).

```
[client]
user=tssfsoas_Admin
password=Hellt0cell
host=localhost
port=3306
```

Lock down ACL (PowerShell as Administrator):

```
icacls "D:\HMS-Data\hms-backups\mysql-backup.cnf" /inheritance:r
icacls "D:\HMS-Data\hms-backups\mysql-backup.cnf" /grant:r "Administrators:(R)"
icacls "D:\HMS-Data\hms-backups\mysql-backup.cnf" /grant:r "SYSTEM:(R)"
icacls "D:\HMS-Data\hms-backups\mysql-backup.cnf" /grant:r "TSSF\svc-hms-backup:(R)"
```

Create service account `TSSF\svc-hms-backup` (or use existing backup operator account) with no interactive logon.

18.5 Automated backup script (included)

Script location: `C:\HMS_JS\docs\scripts\08-tssf-hms-backup.ps1`

- MySQL logical dump via `mysqldump --single-transaction`
- Robocopy mirror of `uploads/` to a timestamped folder
- Snapshot copy of `.env` to the config vault
- Retention purge (30 daily SQL dumps; 7 upload mirrors)
- Log file under `hms-backups\logs\`

Manual test run (as backup operator):

```
powershell -ExecutionPolicy Bypass -File "C:\HMS_JS\docs\scripts\08-tssf-hms-backup.ps1"
```

Verify: new `.sql` file in `mysql-backups\`, log ends with `backup completed successfully`.

18.6 Schedule with Windows Task Scheduler

1 Open Task Scheduler → Create Task (not Basic Task).

2 General tab: Name `TSSF SOA HMS Nightly Backup`; run whether user is logged on or not; run with highest privileges; configure for Windows Server.

3 Triggers: Daily at **02:00**; repeat disabled; stop if runs longer than 2 hours.

4 Actions: Start a program —

```
Program: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
Arguments: -ExecutionPolicy Bypass -File "C:\HMS_JS\docs\scripts\08-tssf-hms-backup.ps1"
Start in: C:\Program Files\ZAIZENS\HMS
```

5 Security: Run as TSSF\svc-hms-backup ; grant "Log on as a batch job".**6 Settings:** If task fails, restart every 15 minutes up to 3 attempts; send email alert if SMTP configured (optional).**18.7 Offsite and offline copies**

Method	Procedure	Frequency
Hospital NAS (secondary site)	Robocopy D:\HMS-Data\mysql-backups and latest upload mirror to \\NAS-TSSF\HMS-Backup	Daily after local backup
Encrypted USB vault	Copy weekly full dump + uploads to BitLocker USB; store in hospital admin safe or offsite	Weekly
Air-gapped archive	Monthly SQL dump to read-only media for regulatory retention	Monthly

Ransomware protection: Offsite copies must not be continuously writable from the HMS server (use NAS snapshots, WORM, or disconnected USB). An attacker who encrypts D: must not simultaneously destroy all backup tiers.

18.8 Monthly archive job (optional second task)

On the 1st of each month at 03:00, copy the latest dump to a monthly folder and compress:

```
$src = Get-ChildItem "D:\HMS-Data\mysql-backups\tssfsas_HMS_*.sql" | Sort-Object LastWriteTime -Descending |
Select-Object -First 1
$dest = "D:\HMS-Data\mysql-backups\monthly\tssfsas_HMS_$(Get-Date -Format yyyy-MM).sql"
Copy-Item $src.FullName $dest -Force
Compress-Archive -Path $dest -DestinationPath "$dest.zip" -Force
```

Retain 12 monthly archives; purge older files manually or via scheduled script.

18.9 Monitoring backup success

- ☐ Review latest log in D:\HMS-Data\hms-backups\logs each morning (IT duty roster)
- ☐ Alert if dump size drops > 30% unexpectedly (possible partial failure)
- ☐ Confirm newest .sql file timestamp matches last night
- ☐ Alert if no backup file created within 26 hours
- ☐ Include backup status in weekly IT report to hospital administration

18.10 Restore procedure — database

Use case: Database corruption, accidental mass delete, failed upgrade rollback.

1 Stop HMS service — nssm stop ZAIZENS-HMS (prevents writes during restore).

2 Identify backup file — e.g. D:\HMS-Data\mysql-backups\tssfssoas_HMS_2026-05-25_020015.sql .

3 Optional — restore to test DB first on UAT VM before touching production.

4 Restore production database:

```
mysql -u root -p -e "DROP DATABASE IF EXISTS tssfssoas_HMS; CREATE DATABASE tssfssoas_HMS CHARACTER SET utf8mb4 COLLATE utf8mb4_unicode_ci;"
mysql -u root -p tssfssoas_HMS < "D:\HMS-Data\mysql-backups\tssfssoas_HMS_2026-05-25_020015.sql"
```

1 Start HMS service — nssm start ZAIZENS-HMS .

2 Verify — login, patient search, today's OPD queue, one financial report.

3 Document incident — record data loss window (RPO achieved) and root cause.

18.11 Restore procedure — uploads folder

```
nssm stop ZAIZENS-HMS
robocopy "D:\HMS-Data\uploads-backups\2026-05-25_020015" "D:\HMS-Data\uploads" /MIR
nssm start ZAIZENS-HMS
```

/MIR replaces the live folder to match the backup snapshot. Confirm timestamp folder matches the database restore date for consistency.

18.12 Restore procedure — configuration (.env)

```
copy "D:\HMS-Data\hms-backups\config\env_2026-05-25_020015.env" "C:\Program Files\ZAIZENS\HMS\.env"
icacls "C:\Program Files\ZAIZENS\HMS\.env" /inheritance:r
icacls "C:\Program Files\ZAIZENS\HMS\.env" /grant:r "Administrators:(R)" "SYSTEM:(F)" "TSSF\svc-hms:(R)"
```

18.13 Full server disaster recovery

If the HMS server is lost entirely (hardware failure, ransomware):

1 Provision replacement Windows Server; install Node.js 18+, MySQL 8.

2 Restore latest vendor deployment package to C:\Program Files\ZAIZENS\HMS\ .

3 Restore .env from config vault; re-apply NTFS ACLs (Section 15).

4 Restore MySQL database from latest offsite dump (Section 18.10).

5 Restore uploads/ from offsite mirror (Section 18.11).

6 Register Windows service and IIS HTTPS (Sections 16, 19).

7 Run UAT checklist (Section 12) before reopening to staff.

18.14 Recovery testing schedule

Test	Frequency	Responsible	Evidence
Restore DB to isolated VM; verify login + patient record	Quarterly	IT + clinical superuser	Signed test log
Restore single upload file from mirror	Quarterly	IT	Ticket reference
Simulate .env recovery	Annually	IT lead	Checklist ticked
Full DR tabletop (server loss scenario)	Annually	IT + administration	Meeting minutes

18.15 Change control and pre-upgrade backups

Before any HMS version upgrade, module change, or schema migration:

- Run manual backup: `powershell -File C:\HMS_JS\docs\scripts\08-tssf-hms-backup.ps1`
- Copy resulting `.sql` to offsite before proceeding
- Record backup filename in change ticket
- If upgrade fails, restore using Section 18.10 and redeploy previous application package

19. Run HMS as a Windows service

19.1 NSSM (recommended for TSSF SOA)

```
nssm install ZAIZENS-HMS "C:\Program Files\nodejs\node.exe" "C:\Program Files\ZAIZENS\HMS\app.js"
nssm set ZAIZENS-HMS AppDirectory "C:\Program Files\ZAIZENS\HMS"
nssm set ZAIZENS-HMS ObjectName "TSSF\svc-hms" "PASSWORD"
nssm set ZAIZENS-HMS AppEnvironmentExtra NODE_ENV=production
nssm set ZAIZENS-HMS AppStdout "C:\Program Files\ZAIZENS\HMS\tmp\service-stdout.log"
nssm set ZAIZENS-HMS AppStderr "C:\Program Files\ZAIZENS\HMS\tmp\service-stderr.log"
nssm start ZAIZENS-HMS
```

19.2 PM2 (alternative)

```
npm install -g pm2
pm2 start app.js --name tssf-hms --cwd "C:\Program Files\ZAIZENS\HMS"
pm2 save
pm2-startup install
```

20. Troubleshooting

Symptom	Likely cause	Action
Port 3000 in use	Stale Node process	<code>netstat -ano findstr :3000</code> ; stop process or change PORT

Symptom	Likely cause	Action
500 on all pages	DB / .env	Read <code>tmp/crash.log</code> ; run <code>node diagnostic2.js</code>
Permission denied on uploads	NTFS ACL	Grant Modify on <code>uploads/</code> to svc-hms only
Blank React UI	Missing bundle	Verify <code>public/dist/hms-ui.js</code> exists
Wrong hospital name on slips	Branding env	Set <code>HMS_SLIP_HEADER=FRANSohH</code> (Shisong Annex)
404 subscriptions page	Route not mounted	Ensure <code>hmsLicense</code> routes registered in <code>app.js</code>
Session drops frequently	MySQL session store	Check DB connectivity; review <code>tmp/crash.log</code> for ECONNRESET
Integrity alert	File changed	Compare hashes; investigate; restore from golden package
Backup task failed	Wrong mysqldump path / credentials	Check <code>hms-backups\logs\</code> ; verify <code>mysql-backup.cnf</code> ACL
Empty or tiny .sql dump	Wrong DB name or auth failure	Run backup script manually; confirm <code>DB_NAME</code> in <code>.env</code>
Restore fails mid-import	Corrupt dump or disk full	Re-copy offsite backup; ensure 2× DB size free space on <code>D:</code>

22. Complementary implementation scripts

All scripts for TSSF SOA deployment, hardening, backup, and validation are shipped in `C:\HMS_JS\docs\scripts\`. Run them in the order below during initial implementation.

#	Script file	Run as	Purpose
01	<code>01-create-mysql-database.sql</code>	MySQL root	Create DB — uses current password <code>He1lt0cell</code> (Section 9.1)
02	<code>02-tssf-soa.env</code>	—	Production environment template (DB credentials + TSSF branding)
03	<code>03-mysql-backup.cnf</code>	—	MySQL backup credentials file
04	<code>04-setup-data-folders.ps1</code>	Administrator	Create <code>D:\HMS-Data</code> and uploads junction
05	<code>05-install-env.ps1</code>	Administrator	Deploy <code>.env</code> to HMS folder with ACL
06	<code>06-apply-ntfs-hardening.ps1</code>	Administrator	Read-only code; writable uploads/tmp
07	<code>07-install-hms-service.ps1</code>	Administrator	Register <code>ZAIZENS-HMS</code> Windows service (NSSM)
08	<code>08-tssf-hms-backup.ps1</code>	Backup account	Nightly MySQL dump + uploads mirror + config snapshot
09	<code>09-register-backup-task.ps1</code>	Administrator	Schedule script 08 daily @ 02:00
10	<code>10-integrity-baseline.ps1</code>	Administrator	SHA-256 baseline after golden deploy

#	Script file	Run as	Purpose
11	11-restore-database.ps1	Administrator	Restore database from .sql dump
12	12-run-diagnostic.ps1	Administrator	Run diagnostic2.js and save output

22.1 Recommended execution sequence

```
# 1 – Database (MySQL root shell or cmd)
mysql -u root -p < "C:\HMS_JS\docs\scripts\01-create-mysql-database.sql"

# 2 – Data folders
powershell -ExecutionPolicy Bypass -File "C:\HMS_JS\docs\scripts\04-setup-data-folders.ps1"

# 3 – Environment file
powershell -ExecutionPolicy Bypass -File "C:\HMS_JS\docs\scripts\05-install-env.ps1"

# 4 – Copy backup credentials
copy "C:\HMS_JS\docs\scripts\03-mysql-backup.cnf" "D:\HMS-Data\hms-backups\mysql-backup.cnf"

# 5 – NTFS hardening (after HMS files deployed)
powershell -ExecutionPolicy Bypass -File "C:\HMS_JS\docs\scripts\06-apply-ntfs-hardening.ps1"

# 6 – Windows service
powershell -ExecutionPolicy Bypass -File "C:\HMS_JS\docs\scripts\07-install-hms-service.ps1"

# 7 – Test backup
powershell -ExecutionPolicy Bypass -File "C:\HMS_JS\docs\scripts\08-tssf-hms-backup.ps1"

# 8 – Schedule nightly backup
powershell -ExecutionPolicy Bypass -File "C:\HMS_JS\docs\scripts\09-register-backup-task.ps1"

# 9 – Integrity baseline
powershell -ExecutionPolicy Bypass -File "C:\HMS_JS\docs\scripts\10-integrity-baseline.ps1"

# 10 – Validate
powershell -ExecutionPolicy Bypass -File "C:\HMS_JS\docs\scripts\12-run-diagnostic.ps1"
```

22.2 Script folder README

See C:\HMS_JS\docs\scripts\README.md for the same index with prerequisites and security notes.

23. Appendix

A. TSSF SOA naming quick reference

Context	Display text
Legal / org reports	TSSF SOA
Full hospital name (formal)	Franciscan Solidarity of Hearts Hospital
Annex label	FRANSoHH (Shisong Annex)
Payment / thermal slips	FRANSoHH (Shisong Annex)
Software platform brand	ZAIZENS Integrated HMS

B. npm scripts reference

Command	Purpose
npm start	Start HMS
npm run build:ui	Build React bundles
npm run build:deploy	Protected deployment folder
npm run build:deploy:protected	Deploy folder + obfuscation
npm run build:deployment-pdf	Regenerate this PDF
node diagnostic2.js	Environment diagnostic

C. Production folder layout

```
C:\Program Files\ZAIZENS\HMS\      (read-only for svc-hms)
  app.js
  lib\                             (obfuscated in protected build)
  routes\                          (obfuscated in protected build)
  views\
  public\dist\                     (minified UI – no frontend/src)
  locales\en\  locales\fr\
  node_modules\
  tmp\                             (writable)
  uploads\ → D:\HMS-Data\uploads (writable junction)
  .env                             (restricted ACL)

D:\HMS-Data\
  uploads\
  mysql-backups\                   (nightly .sql dumps)
  uploads-backups\                 (robocopy mirrors)
  hms-backups\
    config\                       (.env snapshots)
    logs\                         (backup job logs)
  mysql-backup.cnf                 (restricted credentials)
```

D. Security control summary matrix

Threat	Primary control	Section
Staff copies source code	NTFS deny Users; no Git on server	15
Staff modifies app.js	Read-only ACL on code; integrity monitoring	15
External hacker via internet	No public ports; VPN; HTTPS; firewall	16
Stolen DB credentials	localhost-only MySQL; strong password; encrypted backups	16.6
Unauthorized HMS admin	Individual accounts; ACL; no shared passwords	17
Unlicensed modules enabled	Solution subscription serials	14
Ransomware	Offline backups; separate backup VLAN	18

E. Backup quick reference

Action	Command / location
Run backup now	<code>powershell -ExecutionPolicy Bypass -File C:\HMS_JS\docs\scripts\08-tssf-hms-backup.ps1</code>
Latest dump	<code>D:\HMS-Data\mysql-backups\tssfsoas_HMS_*.sql</code>
Latest log	<code>D:\HMS-Data\hms-backups\logs\backup-*.log</code>
Restore DB	<code>mysql -u root -p tssfsoas_HMS < dumpfile.sql</code> (HMS stopped)
Scheduled task	Task Scheduler → <code>TSSF SOA HMS Nightly Backup @ 02:00</code>
MySQL creds file	<code>D:\HMS-Data\hms-backups\mysql-backup.cnf</code> (restricted ACL)

F. Document control

Version	Date	Changes
1.0	May 2026	Initial generic deployment guide
2.0	May 2026	TSSF SOA client profile; comprehensive security sections 15–17
2.1	May 2026	Premium layout; compact pagination; professional theme
2.2	May 2026	Comprehensive backup strategy & implementation (Section 18); backup script
2.3	May 2026	TSSF DB credentials; <code>docs\scripts\</code> implementation kit (12 scripts)
2.4	May 2026	15-character hardened password documented (Section 9.2); live app unchanged

G. Implementation scripts folder

Full path: `C:\HMS_JS\docs\scripts\`

```
01-create-mysql-database.sql
02-tssf-soa.env
03-mysql-backup.cnf
04-setup-data-folders.ps1
05-install-env.ps1
06-apply-ntfs-hardening.ps1
07-install-hms-service.ps1
08-tssf-hms-backup.ps1
09-register-backup-task.ps1
10-integrity-baseline.ps1
11-restore-database.ps1
12-run-diagnostic.ps1
README.md
```